

ENCUESTA INTEGRAL FAICP 2025-2026

Madurez en Ciberseguridad para Sistemas de Inteligencia Artificial

Marco de Referencia: NIST IR 8596 • AI RMF 1.0 • EU AI Act • ENS • NIS2 • ISO/IEC 42001 • OWASP LLM Top 10

"Esta encuesta no juzga lo que usted hace —ya hay suficientes auditores para eso—, sino que intenta comprender honestamente el estado real de la ciberseguridad de la inteligencia artificial en su organización. Responda con la franqueza de quien sabe que el primer paso para mejorar es saber exactamente desde dónde se parte."

Tiempo estimado: 45-60 minutos | **Versión:** 1.0 — Abril 2026 | **Tratamiento:** Anónimo y agregado (RGPD)

ESCALA DE MADUREZ (para preguntas 1-5)

Nivel	Valor	Significado
Inexistente	1	No existe ningún proceso, política ni control relacionado
Inicial/Ad hoc	2	Existe alguna práctica informal, no documentada ni sistemática
Definido	3	Proceso documentado y aplicado, aunque con excepciones
Gestionado	4	Proceso consistente, medido y en mejora activa
Optimizado	5	Completamente integrado, automatizado y en mejora continua

SECCIÓN 0 • PERFIL ORGANIZACIONAL

P0.1. Cargo principal en la organización:

- ☐ CISO / Responsable de Seguridad de la Información
- ☐ CIO / CTO
- ☐ Director/a de Riesgos o Cumplimiento
- ☐ DPO / Responsable de Privacidad
- ☐ Director/a de Infraestructuras / Operaciones TI
- ☐ Chief AI Officer / Responsable de Proyectos IA
- ☐ Director/a General / Consejo de Administración
- ☐ Consultor/a externo/a con mandato en ciberseguridad
- ☐ Otro: ____

P0.2. Comunidad Autónoma sede principal:

- ☐ Andalucía | ☐ Aragón | ☐ Asturias | ☐ Baleares | ☐ Canarias | ☐ Cantabria
- ☐ Castilla-La Mancha | ☐ Castilla y León | ☐ Cataluña | ☐ C. Valenciana
- ☐ Extremadura | ☐ Galicia | ☐ La Rioja | ☐ Madrid | ☐ Murcia | ☐ Navarra | ☐ País Vasco
- ☐ Ceuta / Melilla | ☐ Múltiples CCAA

P0.3. Sector de actividad principal:

- ☐ AAPP Estatal | ☐ AAPP Autonómica | ☐ AAPP Local | ☐ Sanidad | ☐ Educación
- ☐ Banca / Finanzas / Seguros | ☐ Energía / Utilities | ☐ Telecomunicaciones
- ☐ Transporte / Logística | ☐ Industria / Manufactura | ☐ Comercio
- ☐ Tecnología / TIC | ☐ Consultoría | ☐ Defensa / Seguridad | ☐ Otro: ____

P0.4. Tamaño (empleados):

- ☐ Micro (< 10) | ☐ Pequeña (10–49) | ☐ Mediana (50–249) | ☐ Grande (250–999)
- ☐ Gran organización (1.000–4.999) | ☐ Corporación (≥ 5.000)

P0.5. Estatus NIS2:

- ☐ Operador Esencial (Anexo I) | ☐ Entidad Importante (Anexo II)
- ☐ No aplicable / en determinación | ☐ Desconozco mi categoría

P0.6. Presupuesto anual de ciberseguridad (% del TIC):

- ☐ < 5% | ☐ 5–10% | ☐ 10–15% | ☐ 15–20% | ☐ > 20% | ☐ Sin presupuesto TIC diferenciado

SECCIÓN 1 · FUNCIÓN GOBERNAR (GV)

"Gobernar la IA sin métricas es como presidir un consejo de administración con los ojos vendados: se pueden tomar decisiones, por supuesto, pero la elegancia del gesto no compensa la ausencia de visión."

P1.1. [GV.OC-04] Política formal de uso de IA con aspectos de ciberseguridad:

- ☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

Si ≥ 3, ¿qué elementos cubre?

- ☐ Clasificación de sistemas IA por nivel de riesgo
- ☐ Prohibiciones explícitas de IA (manipulación cognitiva, puntuación social...)
- ☐ RACI de responsabilidades en gestión de IA
- ☐ Requisitos de transparencia y explicabilidad
- ☐ Procedimientos ante incidentes IA
- ☐ Requisitos de formación y concienciación
- ☐ Política de uso de herramientas GenAI por empleados (Shadow AI)
- ☐ Revisión periódica de la política

P1.2. [GV.OC-05] Dependencias de infraestructura crítica introducidas por IA documentadas:

- ☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué dependencias han sido identificadas?

- ☐ Proveedores de modelos en la nube (OpenAI, Google, Anthropic, Microsoft, AWS...)
- ☐ APIs de IA de terceros en procesos críticos
- ☐ Infraestructura propia de entrenamiento / inferencia
- ☐ Dependencias de datos externos para entrenamiento
- ☐ Herramientas MLOps y orquestación de modelos
- ☐ Servicios de vectorización y bases de datos vectoriales (RAG)

P1.3. [GV.RR-04] Riesgos IA adversarial integrados en formación y RRHH:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué formaciones específicas se imparten?

- ☐ Reconocimiento de deepfakes de voz y vídeo
- ☐ Phishing y spear-phishing generado con LLM
- ☐ Manipulación de sistemas IA por empleados (uso indebido)
- ☐ Uso seguro de herramientas GenAI en el puesto
- ☐ Protección de datos de entrenamiento y prompts corporativos
- ☐ Reconocimiento de ataques de ingeniería social potenciados con IA
- ☐ Sin formación específica de IA-ciberseguridad

P1.4. [GV.SC-07] Riesgos de ciberseguridad de proveedores IA evaluados sistemáticamente:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué controles se aplican sobre proveedores IA?

- ☐ Cuestionarios de seguridad específicos para proveedores IA
- ☐ Revisión de políticas de privacidad y uso de datos del proveedor
- ☐ Cláusulas contractuales sobre seguridad de datos de prompts e inferencia
- ☐ Certificaciones requeridas (ISO 27001, SOC 2, ENS...)
- ☐ Evaluaciones periódicas (> 1 vez/año)
- ☐ Plan de continuidad ante discontinuidad del proveedor
- ☐ Sin control sistemático sobre proveedores de IA

P1.5. [AI RMF-GOVERN] Comité o función responsable de ética y riesgos de IA con capacidad de veto:

- ☐ Sí, Comité IA con representación multidisciplinar (legal, ciber, negocio, ética)
- ☐ Sí, pero es un rol individual sin estructura de comité formal
- ☐ En proceso de creación
- ☐ No existe ninguna función de gobernanza IA específica
- ☐ No es aplicable a nuestro contexto (aunque lo pensamos a veces)

P1.6. [EU AI Act Art. 49] Registro formal de sistemas de IA clasificados por nivel de riesgo:

- ☐ Sí, registro completo con clasificación por niveles (inaceptable/alto/limitado/mínimo)
- ☐ Parcialmente, identificados los sistemas de alto riesgo
- ☐ En proceso de realizar el inventario

- [] Sin inventario formal de sistemas de IA
- [] Desconocíamos que había que hacerlo (y apreciamos el recordatorio)

SECCIÓN 2 • FUNCIÓN IDENTIFICAR (ID)

"Uno no puede proteger lo que no sabe que tiene, ni defenderse de lo que no sabe que le pueden hacer. El catálogo de lo desconocido es, paradójicamente, el activo más valioso que cualquier CISO debería construir."

P2.1. [ID.AM-07] Inventario completo de sistemas de IA en producción (AI-BOM):

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué información recoge el inventario?

- [] Nombre y propósito del sistema de IA
- [] Proveedor y versión del modelo base
- [] Datos de entrenamiento utilizados (origen, propietario, fecha)
- [] Propietario interno del sistema (responsable técnico y de negocio)
- [] Nivel de criticidad e impacto en procesos de negocio
- [] Integraciones con otros sistemas y APIs
- [] Clasificación EU AI Act (nivel de riesgo)
- [] Fecha de última revisión de seguridad
- [] Nuestro inventario de IA consiste en una conversación informal en el pasillo

P2.2. [ID.RA-01] Vulnerabilidades específicas de los sistemas de IA identificadas y documentadas:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué categorías de vulnerabilidades IA se han evaluado?

- [] Inyección de prompt (prompt injection) directa e indirecta
- [] Envenenamiento de datos de entrenamiento (data poisoning)
- [] Extracción o inversión del modelo (model extraction / inversion)
- [] Ataques de membresía (membership inference attacks)
- [] Ejemplos adversariales (adversarial examples)
- [] Filtraciones de información durante inferencia
- [] Sesgos explotables que comprometan la integridad del sistema
- [] Ninguna de las anteriores

P2.3. [ID.RA-03] Monitorización del uso adversarial de IA por actores externos:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué fuentes de inteligencia de amenazas IA se consumen?

- [] MITRE ATLAS (tácticas y técnicas adversariales IA)
- [] ENISA Threat Landscape (informes anuales)
- [] Alertas y avisos de INCIBE
- [] Feeds de CTI con marcadores de amenazas IA específicos

- [] Informes sectoriales de ISACs
- [] Sin inteligencia de amenazas IA sistemática

P2.4. [ID.RA-04] Velocidad y automatización de ataques IA incorporada en el modelo de riesgos:

- [] Sí, con modelos cuantitativos que incorporan tasa de explotación IA (EPSS, CVSS+IA)
- [] Sí, cualitativamente en el análisis de impacto y probabilidad
- [] En proceso de adaptar el modelo de riesgos para este factor
- [] No, sin diferenciación entre ataques convencionales y potenciados por IA
- [] Nuestro modelo de riesgos fue diseñado antes de que ChatGPT existiera

P2.5. [OWASP LLM03] Análisis de riesgos de la cadena de suministro de IA realizado:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

SECCIÓN 3 · FUNCIÓN PROTEGER (PR)

"Proteger sistemas de IA es como custodiar una biblioteca que escribe sus propios libros en tiempo real: los controles de acceso clásicos no bastan cuando el libro que se está escribiendo puede reescribir las reglas del archivo."

P3.1. [PR.AA-01] Gestión de identidades y accesos específica para sistemas de IA (agentes, APIs, modelos):

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué controles IAM se aplican a sistemas de IA?

- [] Cuentas de servicio dedicadas y separadas para cada sistema de IA
- [] Rotación periódica de credenciales/API keys de sistemas IA
- [] Principio de menor privilegio aplicado a agentes IA autónomos
- [] Autenticación multifactor para acceso a consolas de gestión de modelos
- [] Auditoría de logs de acceso con retención definida
- [] Revisión periódica de permisos (recertificación)
- [] Los sistemas de IA usan las mismas credenciales que los usuarios humanos

P3.2. [PR.AA-05] Principio de menor privilegio y sandboxing en agentes IA autónomos:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué medidas de contención se aplican?

- [] Restricción del scope de herramientas accesibles por el agente
- [] Límites de recursos (tokens, llamadas API, tiempo de ejecución)
- [] Intervención humana obligatoria antes de acciones de alto impacto
- [] Entornos de ejecución aislados (sandboxes) para agentes en producción
- [] Monitorización de comportamiento en tiempo real
- [] No desplegamos agentes IA autónomos (¡de momento!)

P3.3. [PR.AT-01] Frecuencia y profundidad de formación en amenazas IA:

- [] Anualmente, con contenido específico de IA adversarial actualizado

- ☐ Cada dos años o menos
- ☐ Solo durante incorporación (onboarding)
- ☐ De forma reactiva, tras incidentes o alertas
- ☐ Sin formación específica de amenazas IA

¿Qué contenidos de concienciación IA-ciberseguridad se incluyen?

- ☐ Simulacros de phishing generado con LLM (spear-phishing IA)
- ☐ Reconocimiento de deepfakes en videollamadas y mensajes de voz
- ☐ Protocolos de verificación ante solicitudes urgentes sintéticas
- ☐ Higiene de prompts (no incluir datos sensibles en herramientas GenAI externas)
- ☐ Procedimiento de reporte de incidentes sospechosos de IA
- ☐ Ninguno de los anteriores

P3.4. [PR.DS-01/10] Protección de datos de entrenamiento y modelos de IA en reposo y en uso:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué medidas de protección de datos IA se aplican?

- ☐ Cifrado de modelos en reposo (pesos, embeddings, índices vectoriales)
- ☐ Control de acceso a datasets de entrenamiento con trazabilidad
- ☐ Firma digital de modelos para verificación de integridad
- ☐ Prevención de filtraciones (data leakage) de información sensible en outputs
- ☐ Redacción (scrubbing) de PII en prompts antes de envío a APIs externas
- ☐ Políticas de retención y eliminación de logs de inferencia con datos personales
- ☐ Pruebas periódicas de ataques de inversión de modelo

P3.5. [PR.PS-01] Control de versiones y gestión de configuración de sistemas de IA:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué prácticas de MLOps y control de cambios se aplican?

- ☐ Control de versiones de modelos (model registry)
- ☐ Rastreo de experimentos y métricas de entrenamiento
- ☐ Proceso de aprobación de nuevos modelos antes de producción
- ☐ Tests automatizados de seguridad antes del despliegue
- ☐ Registro de cambios en hiperparámetros y configuraciones
- ☐ Capacidad de rollback automatizado a versiones previas

P3.6. [OWASP LLM06] Evaluación de riesgos de agencia excesiva en sistemas de IA autónomos:

- ☐ Sí, con límites definidos y auditados de acciones autónomas permitidas
- ☐ Parcialmente, pero sin documentación formal de límites
- ☐ En proceso de identificar sistemas con agencia potencial
- ☐ Sin evaluación de este riesgo
- ☐ Nuestros sistemas de IA no tienen capacidad de acción autónoma (aún)

SECCIÓN 4 • FUNCIÓN DETECTAR (DE)

"Detectar es el arte de escuchar lo que el sistema no dice en voz alta. En un entorno con IA, eso incluye escuchar el silencio entre inferencia e inferencia, y saber cuándo ese silencio es demasiado elocuente."

P4.1. [DE.CM-06] Monitorización del tráfico hacia y desde APIs de IA externas:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué aspectos se monitorizan?

- [] Volumen de llamadas y consumo de tokens por sistema/usuario
- [] Detección de prompts que contienen datos sensibles o PII
- [] Análisis de outputs de IA en busca de respuestas anómalas
- [] Alertas ante intentos de prompt injection detectados
- [] Monitorización de costes con alertas de anomalía (LLM10)
- [] Registro de qué empleados usan qué herramientas GenAI externas
- [] No se monitoriza el uso de APIs de IA externas

P4.2. [DE.CM-09] Monitorización en tiempo de ejecución de sistemas de IA autónomos:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué métricas de comportamiento se monitorizan?

- [] Distribución estadística de outputs del modelo (detección de drift)
- [] Frecuencia y tipo de llamadas a herramientas externas por agentes IA
- [] Patrones de acceso a datos (detección de exfiltración vía IA)
- [] Latencia y consumo de recursos (detección de abuso)
- [] Comparación de comportamiento vs. línea de base establecida
- [] No se monitorizan sistemas IA en tiempo de ejecución

P4.3. [AI RMF-MEASURE] Frecuencia de evaluación del model drift en modelos en producción:

- [] Monitorización continua automatizada con alertas
- [] Evaluaciones periódicas programadas (mensual o más frecuente)
- [] Evaluaciones poco frecuentes (trimestral o menos)
- [] Solo ante incidentes o quejas de usuarios
- [] Sin procesos establecidos para detectar model drift
- [] ¿Model drift? (Y aquí llegamos al corazón del asunto)

P4.4. Capacidades del SOC para detectar ataques potenciados por IA:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué capacidades de detección IA tiene el SOC?

- [] Reglas de correlación específicas para patrones MITRE ATLAS
- [] Modelos de ML para detección de anomalías en tráfico IA
- [] Integración de MITRE ATLAS en plataforma SIEM/SOAR
- [] Analistas especializados en amenazas de IA adversarial
- [] Casos de uso de detección de deepfakes y síntesis de voz

- [] Playbooks de respuesta específicos para incidentes de IA
- [] El SOC detecta amenazas convencionales; las de IA son territorio inexplorado

P4.5. [OWASP LLM01] Controles de detección de inyección de prompt en sistemas LLM:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué controles de detección se utilizan?

- [] Filtros de entrada basados en patrones conocidos de inyección
- [] Clasificadores ML para detectar prompts maliciosos
- [] Guardrails configurados en el modelo (instrucciones de sistema robustas)
- [] Monitorización de comportamiento anómalo post-prompt
- [] Red teaming periódico específico de inyección de prompt
- [] Sin controles específicos de detección de prompt injection

SECCIÓN 5 · FUNCIÓN RESPONDER (RS)

"Cuando un sistema de IA es comprometido, la primera pregunta no es '¿qué hemos perdido?' sino '¿qué decisiones ya tomó el sistema comprometido antes de que lo detectáramos?' Esa pregunta tiene la altura de un edificio y muy pocas organizaciones tienen la escalera adecuada."

P5.1. [RS.AN-03] Playbooks específicos de respuesta a incidentes con IA como vector o sistema comprometido:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Para qué escenarios de incidente IA existen playbooks?

- [] Envenenamiento de datos de entrenamiento detectado post-producción
- [] Modelo comprometido (sustitución o manipulación de pesos)
- [] Exfiltración de información sensible vía prompts de empleados
- [] Ataque de ingeniería social con deepfake ejecutado con éxito
- [] Manipulación de sistema IA crítico por inyección de prompt
- [] Uso de IA en ataque de ransomware con evasión de detección
- [] Sin playbooks específicos de IA

P5.2. [RS.AN-03] Capacidad de análisis forense específico de sistemas de IA tras incidente:

- [] Sí, con equipo especializado y herramientas de forensics de modelos de IA
- [] Parcialmente, se analizan logs de inferencia pero no los pesos del modelo
- [] Capacidad forense TI convencional, sin especialización IA
- [] Sin capacidad forense propia; dependemos de proveedores externos
- [] La pregunta asume que detectamos los incidentes a tiempo suficiente

P5.3. [EU AI Act Art. 73 + NIS2 Art. 23] Conocimiento y aplicación de plazos de notificación de incidentes graves de IA:

- [] Sí, procedimientos documentados y probados para notificaciones a AESIA e INCIBE/CCN-CERT
- [] Conocemos los plazos pero los procedimientos no están formalizados
- [] En proceso de adaptar procedimientos de notificación

- ☐ Desconocemos los plazos específicos de notificación IA
- ☐ Conocemos NIS2 pero no los requisitos específicos del EU AI Act para incidentes graves

P5.4. Tiempo medio de respuesta (MTTR) ante incidentes de ciberseguridad relacionados con IA:

- ☐ Menos de 1 hora (detección y contención automatizadas)
- ☐ Entre 1 y 4 horas
- ☐ Entre 4 y 24 horas
- ☐ Entre 1 y 7 días
- ☐ Más de 7 días
- ☐ Sin métrica de MTTR específica para incidentes IA
- ☐ No hemos tenido incidentes de IA (o no hemos detectado ninguno, que es una categoría filosóficamente diferente)

SECCIÓN 6 • FUNCIÓN RECUPERAR (RC)

"La recuperación de un sistema de IA comprometido no es un acto técnico: es la reconstitución de un contrato de confianza con todos los usuarios que depositaron sus decisiones en ese sistema."

P6.1. [RC.RP-02] Planes de recuperación específicos para sistemas de IA críticos (incluyendo rollback de modelos):

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

¿Qué elementos incluye el plan de recuperación IA?

- ☐ Backups periódicos de modelos en producción (pesos + configuración)
- ☐ Procedimiento de rollback a versión anterior del modelo
- ☐ Validación de integridad del modelo recuperado antes de reactivación
- ☐ Plan de comunicación a usuarios afectados por comportamiento anómalo
- ☐ Análisis de impacto de decisiones tomadas durante el período de compromiso
- ☐ Pruebas periódicas del plan de recuperación (ejercicios de simulacro)

P6.2. Tiempo Objetivo de Recuperación (RTO) de sistemas de IA críticos:

- ☐ Menos de 1 hora (recuperación automatizada)
- ☐ Entre 1 y 4 horas
- ☐ Entre 4 y 24 horas
- ☐ Entre 1 y 7 días
- ☐ Sin RTO definido para sistemas de IA
- ☐ Nuestros sistemas de IA no son lo suficientemente críticos como para tener RTO (aún)

P6.3. [RC.RP-03] El proceso de recuperación incluye revisión de decisiones tomadas por el sistema comprometido:

- ☐ Sí, con procedimiento formal de auditoría de outputs durante el período de compromiso
- ☐ Parcialmente, revisamos los casos de mayor impacto
- ☐ Lo contemplamos en teoría pero no lo hemos practicado

- ☐ Sin proceso para revisar las decisiones del sistema comprometido
- ☐ No habíamos pensado que esto pudiera ser necesario (y ahora me preocupa)

SECCIÓN 7 • CIBERSEGURIDAD INDUSTRIAL Y OT/ICS CON COMPONENTE IA

Responda solo si opera sistemas de control industrial (SCADA, DCS, PLC) o infraestructuras OT.

P7.1. Componentes de IA en sistemas de control industrial (ICS/OT):

- ☐ Sí, con componentes IA en sistemas críticos de producción o control
- ☐ Sí, en sistemas auxiliares no críticos (mantenimiento, calidad)
- ☐ En proceso de implementación o evaluación
- ☐ No, sin IA en entornos OT actualmente

P7.2. [NIST IR 8596 + ISA/IEC 62443] Evaluación de riesgo de manipulación de sistemas IA-OT adversarial:

☐ 1 · Inexistente ☐ 2 · Inicial ☐ 3 · Definido ☐ 4 · Gestionado ☐ 5 · Optimizado

P7.3. Segregación de red IT/OT completada como medida base de protección:

- ☐ Sí, con segregación completa y zonas DMZ industriales
- ☐ Parcialmente, con controles compensatorios en interfaces IT/OT
- ☐ En proceso de segregación
- ☐ No, los entornos IT y OT están interconectados sin controles específicos

P7.4. Ejercicios específicos de simulación de ciberataque OT que incluyan vectores IA:

- ☐ Sí, ejercicios red team OT + IA al menos anualmente
- ☐ Solo ejercicios tabletop (sin componente técnica activa)
- ☐ Ejercicios convencionales sin escenarios IA
- ☐ Sin ejercicios de ciberseguridad OT

SECCIÓN 8 • CUMPLIMIENTO NORMATIVO

"El cumplimiento normativo es el mínimo que la ley exige. La seguridad real es lo que la prudencia aconseja más allá del mínimo. Ambos son importantes, pero confundirlos es uno de los errores más elegantes que se pueden cometer en ciberseguridad."

P8.1. [EU AI Act] Estadio de implementación del EU AI Act:

- ☐ Cumplimiento completo en todos los requisitos aplicables
- ☐ En proceso avanzado (>75% de requisitos abordados)
- ☐ En proceso inicial (25–75%)
- ☐ Análisis de brechas completado, implementación sin iniciar
- ☐ Análisis de brechas en curso
- ☐ Sin acción de cumplimiento EU AI Act
- ☐ Sin sistemas de IA sujetos al EU AI Act

P8.2. [ENS] Nivel de implementación del Esquema Nacional de Seguridad (si aplica):

- ☐ Certificación ENS vigente | ☐ Auditoría realizada, pendiente certificación
- ☐ En proceso de adecuación | ☐ No estamos sujetos | ☐ Sujetos pero sin iniciar

P8.3. [NIS2] Análisis de brechas NIS2 e implementación de medidas Art. 21:

- ☐ Implementación completa (10 requisitos Art. 21) | ☐ Avanzada (>75%)
- ☐ Parcial (25–75%) | ☐ Análisis completado, plan en curso
- ☐ Análisis en proceso | ☐ Sin acción NIS2

P8.4. [ISO/IEC 42001] Adopción de ISO/IEC 42001 como marco de referencia:

- ☐ Certificación vigente o en proceso
- ☐ Adoptada como referencia interna sin certificación formal
- ☐ En evaluación o planificación
- ☐ Sin evaluación de esta norma
- ☐ Esperamos a que nos la exijan

P8.5. [RGPD + EU AI Act Art. 27] Evaluaciones de Impacto sobre Derechos Fundamentales (FRIA) para IA alto riesgo:

- ☐ Sí, para todos los sistemas de alto riesgo antes del despliegue
- ☐ Solo para los de mayor impacto en derechos de las personas
- ☐ En proceso de definir el procedimiento
- ☐ No, aunque tenemos sistemas que lo requerirían
- ☐ Sin sistemas de IA de alto riesgo

SECCIÓN 9 • AESIA Y ECOSISTEMA REGULATORIO ESPAÑOL

P9.1. Conocimiento y aplicación de las 16 Guías Prácticas de Cumplimiento RIA publicadas por AESIA (dic. 2025):

- ☐ Revisadas todas; adaptando procesos
- ☐ Conocemos las más relevantes para nuestro contexto
- ☐ Sabemos que existen pero no las hemos revisado en profundidad
- ☐ No conocíamos su existencia
- ☐ Demasiado detalladas para nuestro tamaño

P9.2. Participación en el sandbox regulatorio de IA de AESIA:

- ☐ Sí, participamos activamente
- ☐ Solicitado o en proceso de solicitud
- ☐ En evaluación
- ☐ No aplicable a nuestro contexto
- ☐ No conocíamos la existencia del sandbox

P9.3. Registro de incidentes de IA preparado para notificaciones a AESIA (Art. 73 EU AI Act):

- ☐ Sí, sistema de notificación formal configurado y probado
- ☐ Registro existente pero proceso de notificación a AESIA en definición

- ☐ En proceso de implementación
- ☐ Sin registro específico de incidentes de IA

SECCIÓN 10 • AUTOEVALUACIÓN GLOBAL

P10.1. Madurez global en ciberseguridad para sistemas de IA (1 = prácticamente inexistente; 10 = referente en el sector):

Valor: ____ (1-10)

P10.2. Tres principales obstáculos para mejorar la postura de ciberseguridad IA (*máximo 3 opciones*):

- ☐ Falta de presupuesto específico
- ☐ Ausencia de talento especializado en seguridad IA
- ☐ Falta de comprensión y apoyo de la alta dirección
- ☐ Complejidad y fragmentación regulatoria (EU AI Act, NIS2, ENS, RGPD...)
- ☐ Ausencia de herramientas de mercado específicas
- ☐ Velocidad de adopción IA supera capacidad de controles de seguridad
- ☐ Falta de concienciación sobre riesgos específicos de la IA
- ☐ Dificultad para medir el ROI de inversiones en seguridad IA
- ☐ Resistencia organizativa al cambio
- ☐ Dependencia de terceros con bajos estándares de seguridad IA

P10.3. Principal vector de ciberataque IA esperado en los próximos 12 meses (*selección única*):

- ☐ Phishing / spear-phishing generado con LLM hiperpersonalizado
- ☐ Deepfakes de voz o vídeo para fraude o ingeniería social
- ☐ Ransomware con evasión potenciada por ML
- ☐ Ataques automatizados de reconocimiento y explotación
- ☐ Envenenamiento de datos o modelos IA internos
- ☐ Explotación de agentes IA autónomos (inyección de prompt indirecta)
- ☐ Ataques a infraestructura OT/ICS con componentes IA
- ☐ Desinformación y manipulación de decisiones mediante IA generativa
- ☐ No lo sé (y esa incertidumbre es exactamente el problema)

P10.4. ¿Desearía recibir el informe comparativo por CCAA y sector?

- ☐ Sí | ☐ Solo si garantizan anonimato absoluto | ☐ No

P10.5 — Pregunta Abierta: ¿Qué aspecto de la ciberseguridad para sistemas de IA está insuficientemente cubierto por los marcos normativos actuales?

[Campo de texto libre — su perspectiva es el activo más valioso de esta encuesta]

DECLARACIÓN DE CONFORMIDAD

Al enviar esta encuesta, el/la respondente declara que las respuestas reflejan, a su mejor saber y entender, la situación real de su organización, y que los datos serán tratados de forma anonimizada conforme al RGPD (UE) 2016/679.

Fecha: __ / *Firma (versión impresa):* __

Kit FAICP 2025–2026 · Documento (a) · Versión 1.0 · Abril 2026

Basado en: NIST IR 8596, AI RMF 1.0, EU AI Act, ENS, NIS2, ISO/IEC 42001, OWASP LLM Top 10 2025, MITRE ATLAS, ENISA ETL 2025